CRYPTO GTU IMP QUE ANS

UNIT 1

Q1. Define Computer Security, Cyber Security, Information Security and Network Security.

1. Computer Security

Definition:
Computer security means protecting a computer system from damage, misuse, or unauthorized access.

Main Points:

Protects hardware, software, and data.
Stops harmful programs like virus, worms, Trojan.
Prevents unauthorized persons from using the computer.
Ensures computer works correctly and safely.
Helps avoid data loss and system failures.

Example:
Using antivirus and password protection.

2. Cyber Security

Definition:
Cyber security means protecting digital devices, networks, and online data from attacks done through the internet.

Main Points:

Protects against hackers, phishing, ransomware, etc.
Includes security for computers, mobiles, tablets, servers.
Ensures safe online banking, e-commerce, and communication.
Stops attackers from stealing or destroying your data.
Deals with both technical and human-related threats.

Example:
Two-factor authentication, strong passwords, firewall.

3. Information Security (InfoSec)

Definition:
Information Security protects any type of information (digital or paper) from unauthorized access, change, or destruction.

Main Points:

Based on CIA Triad:

1. Confidentiality → Information should remain secret.
2. Integrity → Information should remain correct.
3. Availability → Information should be available when needed.

Applies to computer data, documents, files, records.
Protects information during storage and transmission.
Ensures only authorized people can access it.

Example:
Encrypting a file before storing or sending it.

4. Network Security

Definition:
Network security means protecting data moving over a network from attacks or unauthorized access.

Main Points:

Protects communication between sender and receiver.
Prevents attacks like eavesdropping, spoofing, man-in-the-middle, etc.
Uses tools like firewalls, IDS, encryption.
Ensures data reaches the receiver safely and correctly.
Maintains secure internet and LAN connections.

Example:
Using HTTPS, VPN, or encrypted Wi-Fi.

Q2. List and explain the five essential network security requirements.
Network security must meet five important requirements to protect data and communication. These requirements help keep information safe from hackers and attacks.

1. Confidentiality

Meaning:
Confidentiality means keeping data secret so that only authorized people can read it.

Key Points:

Prevents others from seeing your data.
Protects sensitive information like passwords, bank details.
Achieved using encryption and access control.
Even if attackers capture the data, they cannot understand it.

Example:
Using HTTPS or AES encryption while sending data online.

2. Integrity

Meaning:
Integrity means data must remain correct and unchanged during storage or transmission.

Key Points:

Protects data from modification, insertion, or deletion.
Ensures data reaches the receiver exactly as sent.
Achieved using hash functions and digital signatures.

Example:
If you send ₹100 to someone, the amount should not become ₹1000 due to an attack.

3. Availability

Meaning:
Availability means the system and data must be available whenever users need it.

Key Points:

Protects against attacks like DDoS that block services.
Ensures continuous access to websites, servers, and data.
Achieved using backups, load balancers, redundant servers.
Prevents system downtime.

Example:

Banking websites must remain available 24×7.

4. Authentication

Meaning:
Authentication ensures that both sender and receiver are genuine and not fake.

Key Points:

Verifies identity using passwords, biometrics, OTP, certificates.
Prevents impersonation attacks.
Ensures only authorized users enter the system.

Example:
Logging into Gmail using username + password + OTP.

5. Non-Repudiation

Meaning:
Non-repudiation ensures that the sender cannot deny sending the message and the receiver cannot deny receiving it.

Key Points:

Ensures accountability.
A proof is created that a communication took place.
Achieved using digital signatures and audit logs.
Useful in legal and financial transactions.

Example:
Digital signature on an email—you cannot deny later that you sent it.

Q3. Explain the OSI Security Architecture with its components.
The OSI Security Architecture is a framework created by ISO to help understand how to secure communication over a network.
It tells us what security services are needed, what security attacks may happen, and what mechanisms protect the system.

It has three main components:

1. Security Attacks
These are actions that harm or threaten the security of data or communication.

Types of Attacks:

A. Passive Attacks

The attacker does not change the message; only tries to observe or read data.
Snooping
Eavesdropping
Traffic analysis

B. Active Attacks

The attacker modifies, deletes, inserts, or spoofs data.
Masquerade (pretending to be someone else)
Replay attack
Modification of message
Denial of Service (DoS)

2. Security Services
These are functions that protect data from security attacks.
They answer the question: “What type of protection do we need?”

The OSI model defines six main security services:

1. Authentication – Verify the identity of users.
2. Access Control – Restrict unauthorized users.
3. Data Confidentiality – Keep the data secret using encryption.
4. Data Integrity – Ensure data is not modified.
5. Non-Repudiation – No one can deny an action/message.
6. Availability – Services should be available when needed.

These services describe exactly what security must be achieved.

3. Security Mechanisms
These are tools, methods, or techniques used to implement (apply) the security services.
They answer the question: “How will we provide security?”

Security mechanisms include:

A. Specific Security Mechanisms

Used for a particular security service.
Encryption → for confidentiality
Digital signature → for authentication & non-repudiation
Access control list (ACL) → to restrict users
Authentication exchange → to verify identity
Data integrity check → hashing, MAC

B. Pervasive Security Mechanisms

These support all areas of security.
Security audit
Event logging
Recovery mechanisms

Security management

These mechanisms describe how security is actually done in the system.

Easy Diagram (Text Form)

OSI Security Architecture

```
-------------------------------
|     Security Attacks        |
-------------------------------
|     Security Services       |
-------------------------------
|    Security Mechanisms      |
-------------------------------
```

Simple Explanation

Security Attacks → What can go wrong
Security Services → What protection we need
Security Mechanisms → How we apply protection

Q4. Discuss the six major security services in a communication system with examples.

Security services are methods or functions used to protect data and communication from threats. A communication system usually provides six main security services.

1. Authentication

Meaning:
Ensures that the sender and receiver are who they claim to be.

Key Points:

Confirms identity of users or systems
Prevents masquerade attacks (fake identity)
Uses passwords, digital certificates, OTPs

Example:
Logging into Gmail using username + password + OTP.

2. Access Control

Meaning:
Prevents unauthorized users from accessing data or resources.

Key Points:

Only authorized users can read, write, or modify data
Can be implemented using Access Control Lists (ACL) or role-based access

Example:
Only HR department can access employee salary data.

3. Data Confidentiality

Meaning:
Keeps data secret so that unauthorized people cannot read it.

Key Points:

Uses encryption to protect data during storage or transmission
Ensures privacy of sensitive information

Example:
Bank transactions using AES encryption or HTTPS websites.

4. Data Integrity

Meaning:
Ensures that data is not altered or tampered with during transmission.

Key Points:

Protects against modification, insertion, or deletion of data
Uses hash functions or Message Authentication Codes (MAC)

Example:
Ensuring an online payment amount is not changed during transmission.

5. Non-Repudiation

Meaning:
Prevents either the sender or receiver from denying a transaction or message.

Key Points:

Creates proof of sending and receiving messages
Useful in legal and financial communications
Implemented using digital signatures

Example:
A signed email or a digitally signed invoice.

6. Availability

Meaning:
Ensures that network services and data are available whenever needed.

Key Points:

Protects against denial-of-service attacks
Uses redundancy, backups, and failover systems

Example:
A bank's online service should be available 24×7 without downtime.

Q5. Explain the model for network security with sender, receiver, security transformation and insecure channel.

A network security model explains how secure communication takes place between a sender and a receiver over an insecure network.

Components of the Network Security Model

1. Sender (Source)
The sender is the person or system that wants to send a message.
Prepares the message in plain text.

Example: Alice wants to send "HELLO" to Bob.

2. Security Transformation
The message is transformed to protect it.
Usually involves encryption to turn plaintext into ciphertext.
Uses security keys (symmetric or asymmetric).
Ensures that even if attackers see the message, they cannot read it.

Example:
Using AES encryption with a shared key.

3. Secret Information (Keys)
A key is required to encrypt and decrypt the message.
Symmetric key: Same key for sender and receiver.
Asymmetric key: Public key for encryption, private key for decryption.

4. Insecure Channel
The ciphertext travels through an insecure network, like the internet.
Attackers may intercept or modify the data.
The security transformation ensures that intercepted data cannot be understood.

5. Receiver (Destination)
The receiver uses the key and decryption method to convert ciphertext back into plaintext.
Only the authorized receiver can read the original message.

Example:
Bob receives the encrypted message and uses the shared key to decrypt “HELLO”.

Process Flow

1. Sender → Plaintext message
2. Encryption (Security Transformation) → Ciphertext
3. Transmit through insecure channel
4. Receiver → Decrypt ciphertext → Original message

Diagram (Text Form)

Sender (Plaintext)
|
v
Security Transformation (Encryption)
|
v
Insecure Channel (Ciphertext)
|
v
Receiver (Decryption)
|
v
Receiver gets Original Message

OR

Q5. Classify cryptography into key-less, single-key and two-key algorithms with examples

Cryptography is the science of keeping information secure. It is classified into three main types based on the use of keys.

1. Key-less Cryptography (Classical Ciphers)

Definition:
These ciphers do not use any key for encryption or decryption.

Security depends on the method itself.

Key Points:

Uses simple substitution or rearrangement of letters
Easy to implement but not very secure

Examples:

1. Caesar Cipher – Shift letters by a fixed number
Plaintext: HELLO → Ciphertext: KHOOR (shift +3)
2. Rail Fence Cipher – Writes letters in a zig-zag pattern
3. Playfair Cipher – Uses a 5×5 letter matrix to encrypt pairs of letters

2. Single-Key Cryptography (Symmetric-Key Cryptography)

Definition:
Uses one secret key for both encryption and decryption.

Key Points:

Fast and suitable for large data
Key must be kept secret
Main challenge: key distribution

Examples:

1. AES (Advanced Encryption Standard) – Widely used modern block cipher
2. DES (Data Encryption Standard) – Older block cipher
3. RC4 – Stream cipher
4. Classical polyalphabetic ciphers like Hill cipher, Vigenère cipher

3. Two-Key Cryptography (Asymmetric-Key Cryptography)

Definition:
Uses two keys:

1. Public Key → Encryption

2. Private Key → Decryption

Key Points:

Solves key distribution problem
Provides digital signatures, authentication, non-repudiation
Slower than symmetric encryption

Examples:

1. RSA Algorithm – Uses large prime numbers for secure communication
2. Diffie–Hellman Key Exchange – Allows two parties to generate a shared secret key
3. Elliptic Curve Cryptography (ECC) – High security with smaller key size

UNIT 2

Q1. Explain divisibility and the division algorithm with proof

1. Divisibility

Definition:
A number a is divisible by another number b ($b \neq 0$) if a can be written as $a = b \times k$, where k is an integer.

Key Points:

If $a = b \times k$, we say "b divides a" and write $b \mid a$.
If b does not divide a, we write $b \nmid a$.
Divisibility is the basis for many concepts in number theory.

Example:

12 is divisible by 4 because $12 = 4 \times 3 \rightarrow 4 \mid 12$
13 is not divisible by 4 $\rightarrow 4 \nmid 13$

2. Division Algorithm

Definition:
The division algorithm states that for any two integers a and b ($b > 0$), there exist unique integers q and r such that:

a = bq + r \quad \text{where } 0 \le r < b
a = dividend
b = divisor
q = quotient

r = remainder

Steps to Apply Division Algorithm:

1. Divide a by b
2. Find quotient q and remainder r
3. Express as $a = bq + r$

Proof of Division Algorithm:

1. Let a and b be integers, $b > 0$.
2. Define the set $S = \{a - bk \mid k \in Z, a - bk \geq 0\}$
This is the set of all non-negative integers of the form $a - bk$
3. By well-ordering principle, S has a smallest element r
4. Then $r = a - bq$ for some integer q, and clearly $0 \leq r < b$
5. Therefore, $a = bq + r$
6. Uniqueness: If $a = bq_1 + r_1 = bq_2 + r_2$ and $0 \leq r_1, r_2 < b$,
Then $b(q_1 - q_2) = r_2 - r_1$
But $|r_2 - r_1| < b \rightarrow q_1 = q_2$ and $r_1 = r_2$

Hence, quotient and remainder are unique.

Example of Division Algorithm:

Divide 17 by 5:

$a = 17, b = 5$
$17 \div 5 \rightarrow$ quotient $q = 3$, remainder $r = 2$
Express as $17 = 5 \times 3 + 2$

Q2. Explain modular arithmetic properties over addition and multiplication

Modular arithmetic is the mathematics of remainders when numbers are divided by a positive integer n. It is used in cryptography and computer science.

1. Definition of Modular Arithmetic
For any integer a and positive integer n, the remainder when a is divided by n is called a mod n.

$a \equiv b \pmod{n}$ means a and b leave the same remainder when divided by n.

Example:

$17 \equiv 5 \pmod{12} \rightarrow 17 \div 12$ remainder = 5

$29 \equiv 2 \pmod 9 \rightarrow 29 \div 9$ remainder = 2

2. Properties of Modular Arithmetic

A. Properties over Addition

1. Closure:
If $a \equiv b \pmod n$ and $c \equiv d \pmod n$, then $a + c \equiv b + d \pmod n$
Example: $17 \equiv 5 \pmod{12}$, $10 \equiv 4 \pmod 6 \rightarrow 17 + 10 \equiv 5 + 4 \pmod ?$

2. Associative Law:
$(a + b) + c \equiv a + (b + c) \pmod n$

3. Commutative Law:
$a + b \equiv b + a \pmod n$

4. Existence of Additive Identity:
$a + 0 \equiv a \pmod n$

5. Existence of Additive Inverse:
For each a, there exists -a such that $a + (-a) \equiv 0 \pmod n$

B. Properties over Multiplication

1. Closure:
If $a \equiv b \pmod n$ and $c \equiv d \pmod n$, then $a \times c \equiv b \times d \pmod n$

2. Associative Law:
$(a \times b) \times c \equiv a \times (b \times c) \pmod n$

3. Commutative Law:
$a \times b \equiv b \times a \pmod n$

4. Existence of Multiplicative Identity:
$a \times 1 \equiv a \pmod n$

5. Distributive Law:
$a \times (b + c) \equiv a \times b + a \times c \pmod n$

Example of Modular Arithmetic

Let n = 6:

$5 + 4 \equiv 3 \pmod 6$ → because 5 + 4 = 9, 9 ÷ 6 remainder = 3
$3 \times 4 \equiv 0 \pmod 6$ → because 3 × 4 = 12, 12 ÷ 6 remainder = 0

Q3. Construct the multiplication table for Z_6 and find the multiplicative inverse of 5

1. Definition
$Z_6 = \{0, 1, 2, 3, 4, 5\}$

It is the set of integers modulo 6.
Multiplicative inverse of an element a is a number b such that:

a × b ≡ 1 \ (\text{mod } 6)
Only numbers coprime with 6 have multiplicative inverses modulo 6.

2. Multiplication Table for Z_6

×	0	1	2	3	4	5
0	0	0	0	0	0	0
1	0	1	2	3	4	5
2	0	2	4	0	2	4
3	0	3	0	3	0	3
4	0	4	2	0	4	2
5	0	5	4	3	2	1

3. Finding the Multiplicative Inverse of 5

We need b such that:
5 × b ≡ 1 \ (\text{mod 6})

Check each element in Z_6:

b	0	1	2	3	4	5
5×b mod 6	0	5	4	3	2	1

$5 \times 5 \equiv 1 \pmod 6$

So, multiplicative inverse of 5 in Z_6 is 5.

Q4. Construct the addition table for Z_4 and find the additive inverse of each element

1. Definition
$Z_4 = \{0, 1, 2, 3\}$

It is the set of integers modulo 4.
Additive inverse of an element a is a number b such that:

a + b ≡ 0 \ (\text{mod } 4)

This means when we add a and b, the result is 0 modulo 4.

2. Addition Table for Z_4

+	0	1	2	3
0	0	1	2	3
1	1	2	3	0
2	2	3	0	1
3	3	0	1	2

3. Finding Additive Inverse of Each Element

0: 0 + 0 ≡ 0 → inverse of 0 is 0

1: 1 + 3 ≡ 0 → inverse of 1 is 3

2: 2 + 2 ≡ 0 → inverse of 2 is 2

3: 3 + 1 ≡ 0 → inverse of 3 is 1

Q5. Use Extended Euclidean Algorithm to find GCD(161, 28) and values of s and t
1. Definition of Extended Euclidean Algorithm

The Extended Euclidean Algorithm finds:

1. GCD of two numbers a and b
2. Integers s and t such that:

\text{GCD}(a, b) = s \cdot a + t \cdot b
It is useful in modular arithmetic and cryptography.

2. Steps to Find GCD Using Extended Euclidean Algorithm

We need to find GCD(161, 28).

Step 1: Apply Euclidean Algorithm

Divide 161 by 28 repeatedly:

1. 161 ÷ 28 = 5 remainder 21 → 161 = 28 × 5 + 21

2. 28 ÷ 21 = 1 remainder 7 → 28 = 21 × 1 + 7

3. 21 ÷ 7 = 3 remainder 0 → 21 = 7 × 3 + 0

GCD = 7

Step 2: Express GCD as Linear Combination

We backtrack to find integers s and t:

1. From step 2: 7 = 28 − 21 × 1

2. From step 1: 21 = 161 − 28 × 5

Substitute 21 in step 2:

7 = 28 − (161 − 28 × 5) × 1

7 = 28 − 161 × 1 + 28 × 5

7 = 28 × 6 − 161 × 1

So, s = −1, t = 6

7 = (−1) × 161 + 6 × 28

Q6. Use Euclidean Algorithm to find GCD(119, 544)

1. Definition of Euclidean Algorithm
The Euclidean Algorithm is a method to find the GCD (Greatest Common Divisor) of two numbers.

Steps:

1. Divide the larger number by the smaller number.
2. Take the remainder.
3. Replace the larger number with the smaller number, and the smaller number with the remainder.
4. Repeat until the remainder is 0.
5. The last non-zero remainder is the GCD.

2. Steps for GCD(119, 544)

1. Divide 544 by 119:

544 ÷ 119 = 4 \text{ remainder } 68
544 = 119 × 4 + 68

2. Divide 119 by 68:

119 ÷ 68 = 1 \text{ remainder } 51
119 = 68 × 1 + 51

3. Divide 68 by 51:

68 ÷ 51 = 1 \text{ remainder } 17
68 = 51 × 1 + 17

4. Divide 51 by 17:

51 ÷ 17 = 3 \text{ remainder } 0
51 = 17 × 3 + 0

GCD = 17

3. Summary Table

Step	Division	Remainder
1	544 ÷ 119	68
2	119 ÷ 68	51
3	68 ÷ 51	17
4	51 ÷ 17	0

GCD = 17

OR

Q7. What is a brute-force attack? How can it be defended against?

1. Definition of Brute-Force Attack

A brute-force attack is a method where an attacker tries all possible combinations of passwords, keys, or encryption to gain unauthorized access.
It is a trial-and-error attack and works until the correct key or password is found.

Key Points:

Very simple concept, but can be time-consuming
Works on weak passwords or short keys
Common in password cracking, encryption breaking

2. How Brute-Force Attack Works

1. Attacker selects a target system (e.g., login page).
2. Attacker tries all possible password combinations automatically.
3. When the correct password is found, access is granted.

Example:

Password: “AB12”
Attacker tries: “AAAA”, “AAAB”, …, “AB12” → succeeds at last attempt

3. Defense Against Brute-Force Attack

A. Use Strong Passwords

Use long passwords with letters, numbers, symbols
Avoid simple words or predictable sequences

B. Account Lockout Policy

Lock the account after 3–5 failed login attempts

C. Use CAPTCHA

Prevents automated login attempts

D. Use Two-Factor Authentication (2FA)

Even if password is guessed, attacker cannot login without second factor

E. Strong Encryption

Use long keys in encryption algorithms (e.g., 128-bit or 256-bit AES)
Makes brute-force practically impossible

F. Monitor and Alert

Detect repeated login failures or suspicious activity

Q8. Encrypt “SECURITY” using Rail Fence Cipher with depth 3

1. Definition of Rail Fence Cipher

Rail Fence Cipher is a transposition cipher.
Letters of the plaintext are written in a zig-zag pattern across multiple rows (rails).
Ciphertext is obtained by reading row by row.
Depth = number of rails (rows).

2. Steps to Encrypt

Plaintext: SECURITY
Depth: 3

Step 1: Write letters in zig-zag pattern

3 rails (rows):

Rail 1: S U I Y
Rail 2: E C R T
Rail 3: C I

Arrange in zig-zag:

Row 1: S U I Y
Row 2: E C R T
Row 3: C I

Step 2: Read row by row

Row 1: S U I Y → SUIY

Row 2: E C R T → ECRT

Row 3: C I → CI

Step 3: Combine rows

\text{Ciphertext} = SUIY + ECRT + CI

Ciphertext = SUIYECRTCI

Q9. Encrypt “HELL” using Multiplicative Cipher with key = 7

1. Definition of Multiplicative Cipher

A Multiplicative Cipher is a type of substitution cipher.
Each letter of the plaintext is converted to a number (A=0, B=1, …, Z=25).

Encryption formula:

C = (P \times K) \mod 26
C = ciphertext letter number
P = plaintext letter number
K = key (must be coprime with 26 for inverse to exist)

2. Steps to Encrypt

Step 1: Convert letters to numbers

Letter	H	E	L	L
Number	7	4	11	11

(A=0, B=1, …, Z=25)

Step 2: Apply encryption formula C = (P × K) mod 26

Key K = 7

1. H → (7 × 7) mod 26 = 49 mod 26 = 23 → X
2. E → (4 × 7) mod 26 = 28 mod 26 = 2 → C
3. L → (11 × 7) mod 26 = 77 mod 26 = 25 → Z
4. L → same as above → 25 → Z

Step 3: Convert numbers back to letters

Number	23	2	25	25
Letter	X	C	Z	Z

Ciphertext = XCZZ

Q10. Find the multiplicative inverse of 11 in Z_{26}

1. Definition of Multiplicative Inverse
In modular arithmetic, the multiplicative inverse of a number a modulo n is a number b such that:

a \times b \equiv 1 \ (\text{mod } n)

b exists only if a and n are coprime (GCD(a, n) = 1).

2. Problem

Find b such that:

11 \times b \equiv 1 \ (\text{mod 26})

Check if 11 and 26 are coprime:

GCD(11, 26) = 1 → Yes, inverse exists

3. Method: Trial or Extended Euclidean Algorithm

Step 1: Try small numbers b = 1, 2, …, 25

11 \times b \mod 26

11 × 1 = 11 mod 26 → 11 ❌

11 × 2 = 22 mod 26 → 22 ❌

11 × 3 = 33 mod 26 → 7 ❌

11 × 19 = 209 mod 26 → 1 ✅

So, multiplicative inverse of 11 modulo 26 is 19

Step 2: Verification

11 × 19 = 209
209 ÷ 26 = 8 remainder 1 → 209 ≡ 1 (mod 26)

UNIT 3

Q1. Differentiate between Monoalphabetic and Polyalphabetic Ciphers with Examples

1. Monoalphabetic Cipher
Definition:
A cipher in which each letter of the plaintext is replaced by a fixed letter of ciphertext.

Key Feature: Single, fixed substitution for the entire message.

Example: Caesar Cipher

Shift each letter by 3 positions:

Plaintext: HELLO
Ciphertext: KHOOR

Advantages: Simple and easy to implement.

Disadvantages: Easy to break using frequency analysis.

2. Polyalphabetic Cipher
Definition:
A cipher in which a single letter of plaintext can be encrypted differently at different positions using multiple substitution alphabets.

Key Feature: Multiple cipher alphabets are used; the same letter may have different ciphertext symbols.

Example: Vigenère Cipher

Plaintext: HELLO
Key: KEY
Ciphertext: RIJVS (each letter encrypted differently based on the key)

Advantages: More secure than monoalphabetic cipher.

Disadvantages: Slightly more complex to implement.

Q2. Encrypt “HELLO” using Affine Cipher with key (a = 5, b = 8)
1. Definition of Affine Cipher
Affine Cipher is a type of monoalphabetic substitution cipher.

Encryption formula:

$$E(x) = (a \cdot x + b) \mod 26$$

Where:

= position of plaintext letter (A=0, B=1, … Z=25)

= keys (a must be coprime with 26)

= ciphertext letter

2. Steps to Encrypt “HELLO”

Step 1: Convert letters to numbers (A=0, B=1, ..., Z=25)

Letter	H	E	L	L	O
Number	7	4	11	11	14

Step 2: Apply Affine encryption formula

1. H → 7
2. E → 4
3. L → 11
4. L → 11
Same as above → 11 → L
5. O → 14

Step 3: Convert numbers back to letters

Number	17	2	11	11	0
Letter	R	C	L	L	A

3. Ciphertext

HELLO → RCLLA

Q3. Explain Hill Cipher with a 3×3 matrix example. Use plaintext “ACT”

1. Definition of Hill Cipher

Hill Cipher is a polygraphic substitution cipher.
It encrypts blocks of letters instead of single letters.
Uses matrix multiplication modulo 26 for encryption.
Invented by Lester S. Hill in 1929.

Encryption formula:

C = (K \cdot P) \mod 26

Where:

= Ciphertext vector

= Key matrix (size 3×3 for 3-letter blocks)

= Plaintext vector

2. Steps to Encrypt “ACT”

Step 1: Convert plaintext to numbers (A=0, B=1, ..., Z=25)

Letter	A	C	T
Number	0	2	19

So plaintext vector

Step 2: Choose a 3×3 key matrix

Example key matrix:

$$K = \begin{bmatrix} 6 & 24 & 1 \\ 13 & 16 & 10 \\ 20 & 17 & 15 \end{bmatrix}$$

Key matrix must be invertible modulo 26.

Step 3: Multiply key matrix with plaintext vector

$$C = K \cdot P \mod 26$$

Calculation:

1. First row: → P
2. Second row: → O
3. Third row: → H

Step 4: Convert numbers back to letters

Number	15	14	7
Letter	P	O	H

5. Ciphertext

ACT → POH

Q4. Explain RSA algorithm and demonstrate key generation with p=3, q=11
Definition of RSA Algorithm

RSA (Rivest-Shamir-Adleman) is an asymmetric-key cryptography algorithm.

It uses two keys:

1. Public key – for encryption
2. Private key – for decryption

Widely used for secure communication and digital signatures.

Steps for RSA Key Generation

Step 1: Select two prime numbers
Let ,

Step 2: Compute
n = 3 \times 11 = 33
 is used in both public and private keys.

Step 3: Compute Euler's Totient Function
\phi(n) = (p-1)(q-1) = (3-1)(11-1) = 2 \times 10 = 20

Step 4: Choose public key exponent
 should be coprime with

Common choice:
Let's take

Step 5: Compute private key exponent

 satisfies:

d \cdot e \equiv 1 \mod \phi(n)
d \cdot 3 \equiv 1 \mod 20

Solve: → smallest integer

Because

Step 6: Public and Private Keys

Public Key: → used for encryption
Private Key: → used for decryption

Q5. Explain the basic working of RSA algorithm and its key-generation

Definition of RSA
RSA (Rivest-Shamir-Adleman) is an asymmetric encryption algorithm.

Uses two keys:

1. Public key – used for encryption
2. Private key – used for decryption

Provides confidentiality, integrity, and authentication in digital communication.

Key Generation Steps

Step 1: Choose two prime numbers
Select and as large prime numbers.

Step 2: Compute
 is part of both the public and private keys.

Step 3: Compute Euler's Totient Function
This is used to choose the encryption key .

Step 4: Choose public key exponent
 must be coprime with and .
Forms the public key .

Step 5: Compute private key exponent
Find such that:
d \cdot e \equiv 1 \mod \phi(n)

Basic Working of RSA

Step 1: Encryption
Sender converts plaintext message into ciphertext using the recipient's public key .

C = M^e \mod n

Step 2: Decryption
Receiver uses private key to recover the plaintext:

$M = C^d \mod n$

Only the receiver with the private key can decrypt the message.

Example Overview

Suppose , → ,

Choose , compute

Public key = (3, 33), Private key = (7, 33)

Encryption and decryption follow the formulas above.

OR

Q6. What is a Symmetric Cipher Model? Describe its components

Definition of Symmetric Cipher
Symmetric Cipher (or Symmetric-key Cryptography) is a type of encryption where the same key is used for both encryption and decryption.
Also called secret-key cryptography.
Fast and efficient for large amounts of data.

Working Principle

1. Sender and receiver share a secret key before communication.
2. Sender encrypts plaintext using the secret key → ciphertext.
3. Receiver decrypts ciphertext using the same secret key → plaintext.
4. Security depends on keeping the key secret.

Symmetric Cipher Model Components

A. Plaintext
The original readable message that needs to be sent securely.

Example: “HELLO”

B. Encryption Algorithm
Mathematical process used to convert plaintext into ciphertext using the key.

Example: AES, DES, Caesar cipher

C. Secret Key
Shared between sender and receiver.
Must be kept confidential.

Example: Key = 5

D. Ciphertext
Encrypted message that is unreadable without the key.

Example: “MJQQT”

E. Decryption Algorithm
Process to convert ciphertext back into plaintext using the same secret key.

4. Symmetric Cipher Model Diagram

Plaintext ----Encryption (Key)----> Ciphertext ----Decryption (Key)----> Plaintext

Sender uses encryption algorithm + key

Receiver uses decryption algorithm + key

Q7. What is Asymmetric-key Cryptography? Give one example
Definition of Asymmetric-key Cryptography
Also called public-key cryptography.

Uses two different keys:

1. Public key – used for encryption
2. Private key – used for decryption

The public key can be shared with anyone, but the private key must be kept secret.
Provides confidentiality, authentication, and digital signatures.

Working Principle

1. Sender encrypts the message using the receiver’s public key.
2. The encrypted message (ciphertext) is sent over an insecure channel.
3. Receiver decrypts the message using their private key.
4. Only the receiver can read the message because the private key is secret.

Example

RSA Algorithm is the most common example of asymmetric cryptography.

Example flow:

Public Key: (e, n) → shared publicly
Private Key: (d, n) → kept secret

Message encrypted using public key → decrypted only with private key

Advantages

1. No need to share secret keys in advance.
2. Secure communication over insecure channels.
3. Supports digital signatures for authentication.

Disadvantages

1. Slower than symmetric-key cryptography.
2. Requires more computational resources.

Q8. Decrypt "KXFGHG" encrypted using Caesar cipher with shift key 3
Definition of Caesar Cipher

Caesar Cipher is a monoalphabetic substitution cipher.
Each letter in the plaintext is shifted by a fixed number of positions in the alphabet.

Encryption formula:

$C = (P + k) \mod 26$

Decryption formula:

$P = (C - k) \mod 26$

Where:

= plaintext letter number

= ciphertext letter number

= key (shift)

Step 1: Convert ciphertext letters to numbers

Letter K X F G H G

Number 10 23 5 6 7 6

(A=0, B=1, ..., Z=25)

3. Step 2: Apply decryption formula

Shift key

1. K → 10
2. X → 23
3. F → 5
4. G → 6
5. H → 7
6. G → 6

Step 3: Convert numbers back to letters

Number 7 20 2 3 4 3

Letter H U C D E D

Plaintext

Ciphertext “KXFGHG” → Plaintext “HUCDED”

Q9. List the main ingredients (components) of a public-key encryption system

Definition of Public-Key Encryption System

Also called Asymmetric-key Cryptography.

Uses two separate keys:

1. Public key – for encryption
2. Private key – for decryption

Ensures confidentiality, authentication, and integrity of messages.

Main Components / Ingredients

A. Plaintext
The original message that the sender wants to send securely.

Example: “HELLO”

B. Encryption Algorithm
Mathematical process to convert plaintext into ciphertext using the receiver’s public key.

Example algorithms: RSA, ElGamal

C. Public Key
Key used for encryption.
Can be shared publicly with anyone who wants to send a secure message.

D. Private Key
Key used for decryption.
Must be kept secret by the receiver.
Only the private key can decrypt messages encrypted by the public key.

E. Ciphertext
Encrypted message that is unreadable without the private key.
Safe to send over insecure channels.

F. Decryption Algorithm
Converts ciphertext back into plaintext using the private key.

G. Key Management
System to generate, store, distribute, and revoke keys securely.
Ensures keys are not stolen or misused.

Q10. Encrypt “ENCRYPTION” using Playfair cipher with key “MONARCHY”
Definition of Playfair Cipher

Playfair Cipher is a digraph substitution cipher.
Encrypts pairs of letters (digraphs) instead of single letters.
Invented by Charles Wheatstone, popularized by Lord Playfair.
Uses a 5×5 key matrix containing letters A–Z (I/J combined).

Steps to Encrypt

Step 1: Prepare the Key Matrix

Key = “MONARCHY”

Fill letters in matrix row-wise (duplicate letters removed, combine I/J)

M O N A R
C H Y B D
E F G I/J K
L P Q S T
U V W X Z

Step 2: Prepare Plaintext

Plaintext = “ENCRYPTION”

Remove spaces and split into digraphs (pairs of letters)

EN CR YP TI ON

If a pair has the same letters, insert filler letter X (not needed here).

Step 3: Encryption Rules

1. Same row: Replace each letter with the letter to its right (wrap around).
2. Same column: Replace each letter with the letter below (wrap around).
3. Different row & column: Form a rectangle, replace each letter with the letter in the same row but column of the other letter.

Step 4: Encrypt Each Digraph

1. EN

E → row 3, col 1

N → row 1, col 3

Different row & column → rectangle rule → C1 = G (row 3, col 3), N1 = I/J → G I

2. CR

C → row 2, col 1

R → row 1, col 5

Rectangle → C → D (row 2, col 5), R → M (row 1, col 1) → D M

3. YP

Y → row 2, col 3

P → row 4, col 2

Rectangle → Y → H (row 2, col 2), P → Q (row 4, col 3) → H Q

4. TI

T → row 4, col 5

I → row 3, col 4

Rectangle → T → S (row 4, col 4), I → K (row 3, col 5) → S K

5. ON

O → row 1, col 2

N → row 1, col 3

Same row → shift right → O → N, N → A → N A

Step 5: Combine Ciphertext

Ciphertext = GI DM HQ SK NA

Q11. Encrypt "SECURITY" using Rail Fence Cipher with depth 3

Definition of Rail Fence Cipher

Rail Fence Cipher is a transposition cipher.
Letters of the plaintext are written diagonally in a zig-zag pattern across multiple rows (rails).
Ciphertext is obtained by reading row by row.
Depth = number of rails used.

Steps to Encrypt "SECURITY" with Depth 3

Step 1: Write plaintext in zig-zag form

Plaintext = SECURITY

Depth = 3 (three rails)

Rail 1: S I Y
Rail 2: E U T
Rail 3: C R

Letters are placed diagonally top to bottom, then bottom to top.

Step 2: Read row by row

1. Rail 1: S I Y → SIY
2. Rail 2: E U T → EUT
3. Rail 3: C R → CR

Step 3: Combine all rows

Ciphertext = SIYEUTCR

UNIT 4

Q1.List and explain any three web security threats with examples.

Web security threats are attacks or vulnerabilities that compromise the confidentiality, integrity, or availability of web applications, websites, or user data. Below are three important web security threats explained with examples:

1. Phishing

Definition: Phishing is an attack where attackers create fake websites or emails to trick users into revealing sensitive information such as usernames, passwords, or credit card details.

How it works:

1. The attacker sends a fake email or message claiming to be a trusted source (e.g., a bank).
2. The message contains a link to a fraudulent website.
3. The user enters confidential data, which is captured by the attacker.

Example: A fake email from “Bank ABC” asking the user to login via a provided link, which actually leads to a fake website.

Impact: Identity theft, financial loss, and unauthorized account access.

2. Malware / Viruses

Definition: Malware is malicious software designed to damage, disrupt, or gain unauthorized access to computer systems. Types include viruses, worms, trojans, spyware, and ransomware.

How it works:

1. Malware is delivered through email attachments, downloads, or infected websites.
2. Once executed, it can steal data, log keystrokes, or encrypt files for ransom.

Example:

A keylogger installed via a malicious download that captures all typed passwords.
Ransomware encrypting a user's files and demanding payment for the decryption key.
Impact: Data theft, system damage, financial loss, and compromised privacy.

3. Cross-Site Scripting (XSS)
Definition: XSS is an attack where an attacker injects malicious scripts into web pages viewed by other users.

How it works:

1. The attacker inserts scripts into input fields (like comments or forms).
2. When other users access the page, the script executes in their browser.
3. Scripts can steal cookies, session data, or redirect users to malicious websites.

Example: A comment section on a blog containing a script that captures users' login cookies and sends them to the attacker.
Impact: User account hijacking, session theft, and data exposure.

Q2. What is HTTPS? Briefly explain its connection initiation process
Definition of HTTPS

HTTPS stands for HyperText Transfer Protocol Secure.
It is an extension of HTTP that adds security and encryption for data sent between a web browser and a web server.

HTTPS ensures that the communication is:

1. Confidential – Only the intended recipient can read the data.
2. Authentic – The user is connected to the real server, not an impostor.
3. Integrity-protected – Data is not modified or tampered with during transmission.

Example:

Websites like banks, online shopping sites, and email services use HTTPS to protect sensitive user data.

Importance of HTTPS

1. Protects sensitive data like passwords, credit card numbers, and personal information.
2. Prevents attackers from eavesdropping or intercepting data (man-in-the-middle attacks).
3. Provides trust to users by showing a secure padlock icon in the browser.

HTTPS Connection Initiation Process

The HTTPS connection uses SSL/TLS protocols to establish a secure channel. The steps are:

Step 1: Client Hello

The web browser (client) sends a request to the server.
It includes supported encryption algorithms and a random number for key generation.

Step 2: Server Hello

The server responds with its digital certificate and selected encryption method.
The certificate proves the identity of the server and is issued by a trusted Certificate Authority (CA).

Step 3: Certificate Verification

The browser checks if the certificate is valid, trusted, and not expired.
If the certificate is invalid, the browser shows a warning.

Step 4: Key Exchange

Both the browser and the server agree on a session key using asymmetric encryption.
The session key is then used for fast symmetric encryption of all further data.

Step 5: Encrypted Communication

After the key exchange, all data sent between browser and server is encrypted.
This ensures confidentiality and integrity of user information.

Step 6: Connection Closure

Once the session is over, the keys are discarded and the connection is securely closed.

Advantages of HTTPS

1. Secure communication between client and server.
2. Protects sensitive information from hackers.
3. Builds user trust with the padlock icon in browsers.
4. Prevents data tampering and eavesdropping.

Q3. Compare SSL and SET protocols in terms of security features and usage

SSL (Secure Socket Layer)

Purpose: Provides secure communication over the internet.

Encryption: Encrypts data between client and server to protect it from eavesdropping.

Authentication: Only the server is authenticated using a digital certificate.

Usage: General web security for websites, emails, and online applications.

Performance: Faster because it only encrypts the communication channel.

Limitation: SSL does not authenticate the customer; only the server is verified.

SET (Secure Electronic Transaction)

Purpose: Provides secure online credit card transactions.

Encryption: Encrypts payment information separately from order information.

Authentication: Both merchant and customer are authenticated using digital certificates.

Usage: Online payments where sensitive financial data is transmitted.

Performance: Slightly slower due to multiple encryption layers and extra verification.

Advantage: Reduces fraud risk by ensuring that only authorized users can perform transactions.

Comparison Table

Feature	SSL	SET
Purpose	Secure web communication	Secure online credit card payments
Encryption	Encrypts all communication	Encrypts payment info separately from order info
Authentication	Server only	Both merchant and customer
Usage	Websites, email, general online apps	Online shopping and payment transactions
Performance	Faster	Slightly slower due to extra encryption
Security Advantage	Protects data in transit	Prevents fraud and unauthorized payment

Q4. Compare SSL and TLS protocols in terms of version, security, and performance

Definition

SSL (Secure Socket Layer): An older protocol used to secure communication over the internet.

TLS (Transport Layer Security): A newer and improved version of SSL, designed to provide better security.

Versions

Protocol	Versions
SSL	SSL 2.0, SSL 3.0
TLS	TLS 1.0, TLS 1.1, TLS 1.2, TLS 1.3

TLS is backward compatible with SSL but is more secure.

Security

Feature	SSL	TLS
Encryption Algorithms	Older, weaker	Stronger, more modern algorithms
Vulnerabilities	Vulnerable to attacks like POODLE	Improved security, fixes SSL vulnerabilities
Authentication	Server authentication only	Supports server and optionally client authentication

Performance

Feature	SSL	TLS
Speed	Slightly faster due to simpler encryption	Slightly slower but more secure
Efficiency	Basic encryption methods	Optimized with better key exchange and cipher suites

Usage

SSL: Mostly obsolete now; older websites may still use it.

TLS: Widely used in modern HTTPS websites for secure communication.

Q5. Explain the SSL protocol stack with a neat diagram

Definition of SSL Protocol Stack

SSL (Secure Socket Layer) is a protocol that provides security for data transmitted over the internet.

It works between the application layer and the transport layer in the network protocol stack.

SSL ensures:

1. Confidentiality – Data is encrypted so unauthorized users cannot read it.
2. Integrity – Data is not modified or tampered with during transmission.
3. Authentication – Verifies the identity of the server (and optionally the client).

Layers of SSL Protocol Stack

A. SSL Record Layer

Responsible for:

Dividing data into manageable blocks
Encrypting the data for confidentiality
Adding integrity checks (MAC – Message Authentication Code)
Ensures secure transmission of application data.

B. SSL Handshake Layer

Responsible for:

Authentication of client and server using digital certificates
Negotiation of encryption algorithms and keys
Establishing a session key for secure communication

Ensures both parties can trust each other before exchanging sensitive data.

Simple Diagram of SSL Protocol Stack

[Application Layer]
|
[SSL Handshake Layer] → Handles authentication and key exchange
|
[SSL Record Layer] → Handles encryption and integrity
|
[Transport Layer (TCP)]
|
[Network Layer (IP)]

Q6. Explain the process of HTTPS connection initiation to closure
Definition

HTTPS = HyperText Transfer Protocol Secure

It uses SSL/TLS to provide secure communication between a web browser (client) and a web server.

Ensures:

1. Confidentiality – Data is encrypted.
2. Integrity – Data is not tampered with.
3. Authentication – Server (and optionally client) identity is verified.

Steps of HTTPS Connection

Step 1: Client Hello

The browser sends a request to start a secure connection.

It includes:

Supported encryption algorithms (cipher suites)

A random number for key generation

Step 2: Server Hello

The server responds with:

Its digital certificate (proves server identity)

Selected encryption method from the options provided by the client

Server’s random number for key generation

Step 3: Certificate Verification

The browser checks the certificate:

Is it issued by a trusted Certificate Authority (CA)?

Is it valid and not expired?

If valid, the connection proceeds; if invalid, a warning is shown.

Step 4: Key Exchange

Both client and server use asymmetric encryption to agree on a session key.

The session key is used for fast symmetric encryption of all subsequent data.

Step 5: Encrypted Communication

Data sent between the browser and server is now encrypted using the session key.

Ensures confidentiality, integrity, and privacy.

Step 6: Connection Closure

After the session ends, the session key is discarded.

Connection is securely closed, preventing attackers from reusing the key.

OR

Q7. What is HTTPS? How does it differ from HTTP?

Definition of HTTPS

HTTPS stands for HyperText Transfer Protocol Secure.

It is the secure version of HTTP used to communicate between a web browser (client) and a web server.

HTTPS uses SSL/TLS protocols to encrypt the data, ensuring that it cannot be read or tampered with by attackers.

Provides confidentiality, integrity, and authentication.

Importance of HTTPS

Protects sensitive information like:

Passwords
Credit card numbers
Personal information
Prevents attackers from eavesdropping or intercepting data (Man-in-the-Middle attacks).
Builds trust with users; browsers show a padlock symbol for HTTPS websites.

Difference Between HTTP and HTTPS

Feature	HTTP	HTTPS
Full Form	HyperText Transfer Protocol	HyperText Transfer Protocol Secure

Security	No encryption, data is in plain text	Encrypts data using SSL/TLS
Authentication	None	Server is authenticated with a digital certificate
Privacy	Vulnerable to interception and eavesdropping	Provides confidentiality and integrity
Usage	Blogs, simple websites	Banks, e-commerce, email, online transactions
Port Number	80	443

Q8. List common web traffic security approaches

Web traffic security approaches are methods used to protect data and communication over the internet.

Use HTTPS instead of HTTP

Encrypts data between browser and server using SSL/TLS.
Ensures confidentiality and integrity of user information.
Example: Banking websites, e-commerce sites.

Firewalls and Web Application Firewalls (WAF)

Firewall: Filters incoming and outgoing network traffic to prevent unauthorized access.

WAF: Special firewall that protects web applications from attacks like SQL Injection and XSS.

Monitors requests and blocks malicious traffic.

Regular Software Updates and Patches

Keeps servers, browsers, and applications up-to-date.
Fixes security vulnerabilities that attackers could exploit.

Input Validation

Ensures user input is safe and does not contain malicious code.

Prevents attacks such as:

SQL Injection
Cross-Site Scripting (XSS)

Strong Passwords and Two-Factor Authentication (2FA)
Users should use strong, unique passwords.
2FA adds an extra layer of security.
Reduces the risk of unauthorized account access.

Anti-Malware and Antivirus Software

Detects and removes malware, viruses, and spyware.
Protects both users and servers from attacks.

Network Monitoring and Intrusion Detection Systems (IDS)

Monitors network activity for suspicious behavior.
Alerts administrators about possible attacks or intrusions.

Q9. Explain the basic concept of Secure Electronic Transactions (SET) with diagram

1. Definition of SET

SET (Secure Electronic Transaction) is a security protocol designed to secure online credit card payments.
It ensures that payment information is encrypted and both the customer and merchant are authenticated.
Developed by Visa and Mastercard to reduce fraud in online transactions.

2. Features of SET

1. Encryption of Payment Information – Card details are encrypted so that no one can steal them.
2. Authentication – Digital certificates verify the identity of both customer and merchant.
3. Integrity – Ensures that transaction data is not modified during transmission.
4. Fraud Prevention – Reduces risk of unauthorized transactions.

3. How SET Works (Step-wise)

1. Customer places an order on a merchant website.
2. Customer uses SET to encrypt credit card details and order information.
3. Merchant sends the encrypted payment info to the bank/payment gateway.
4. Bank verifies customer's identity and funds.
5. Bank authorizes the transaction and informs the merchant.
6. Merchant delivers the goods/services.

4. Simple Diagram of SET Flow

Customer → Merchant → Bank/Payment Gateway
| | |
Encrypt Receives Verifies & Authorizes
Card & Payment Info Payment
Order Info

Customer: Encrypts payment info and order details.

Merchant: Receives encrypted payment, forwards it to bank.
Bank: Verifies payment, authorizes, and confirms transaction.

Q10. Explain how a Web Application Firewall (WAF) mitigates two common web threats

1. Definition of WAF

WAF (Web Application Firewall) is a security device or software that filters and monitors HTTP/HTTPS traffic to web applications.
It sits between the user and the web server to protect web applications from attacks.
WAF focuses on application layer attacks (Layer 7 of OSI model).

2. Common Web Threats Mitigated by WAF

A. SQL Injection (SQLi)

Threat: Attackers insert malicious SQL queries in input fields to manipulate the database.

WAF Mitigation:

1. Analyzes incoming requests for malicious patterns.
2. Blocks queries containing suspicious SQL commands.

Example: Blocking input like '; DROP TABLE users; --.

B. Cross-Site Scripting (XSS)

Threat: Attackers inject malicious scripts into web pages viewed by other users.

WAF Mitigation:

1. Detects scripts or HTML code that is not allowed.
2. Filters out or neutralizes dangerous input before it reaches the server.

Example: Blocking <script>alert("hacked")</script> in comment sections.

3. Key Advantages of WAF

1. Provides real-time protection for web applications.
2. Can block attacks without affecting legitimate users.
3. Protects against data theft, fraud, and website defacement.
4. Works as an additional layer of security along with HTTPS and IDS.

Q11. Demonstrate the main security advantage of using SET over SSL for online payments

1. Definition of SET and SSL

SSL (Secure Socket Layer):

Encrypts the communication channel between browser and server.
Provides server authentication only.

SET (Secure Electronic Transaction):

Designed specifically for secure online credit card payments.
Authenticates both the customer and the merchant.
Encrypts payment information separately from order information.

2. Main Security Advantages of SET over SSL

A. Dual Authentication

SSL only authenticates the server.
SET authenticates both customer and merchant using digital certificates.
This ensures fraud prevention, as only legitimate users and merchants can perform transactions.

B. Payment Data Protection

SSL encrypts the entire communication channel, but the merchant still receives credit card info.
SET encrypts payment information separately, so even the merchant cannot see sensitive card details.
Reduces the risk of credit card theft or misuse.

C. Integrity and Confidentiality

SET ensures that order and payment information are not altered during transmission.
Provides end-to-end security, protecting both the payment process and sensitive data.

D. Fraud Prevention

SET prevents unauthorized transactions.
Only verified customers can initiate payments.
Only verified merchants can receive payments.

UNIT 5

Q1. Define Intrusion Detection System (IDS) and list its two main approaches

1. Intrusion Detection System (IDS) Definition

IDS is a security system that monitors network or computer system activities.
It is used to detect unauthorized access, attacks, or misuse.
When an intrusion is detected, IDS alerts system administrators.
Helps in preventing damage, theft of data, and maintaining system integrity.

2. Two Main Approaches of IDS

A. Misuse Detection (Signature-based Detection)

Compares system activity with known attack patterns (signatures).
Detects attacks already recorded in the database.
Example: Detecting a virus by its signature.
Pros: Accurate for known attacks.
Cons: Cannot detect new or unknown attacks.

B. Anomaly Detection (Behavior-based Detection)

Monitors normal behavior of users and systems.
Flags activity that deviates from normal patterns.
Example: Detecting a user login at unusual hours.
Pros: Can detect new or unknown attacks.
Cons: May produce false alarms.

Q2. Explain the difference between Masquerader, Misfeasor, and Clandestine Users

1. Classification of Intruders / Unauthorized Users

Intruders or unauthorized users are classified into three types based on their access and intent:

A. Masquerader

A Masquerader is an external attacker.
Pretends to be a legitimate user to gain unauthorized access.
Does not have any valid account on the system.
Example: A hacker trying to log in as an employee to steal data.

B. Misfeasor

A Misfeasor is an insider user.
His authorized access but misuses the privileges.
Performs actions against policy or beyond assigned authority.
Example: An employee copying confidential files to personal storage.

C. Clandestine User

A Clandestine User is a user who gains unauthorized access without being detected.
Often hides their presence for a long time.
Example: A spy installing a backdoor to monitor system secretly.

Q3. What is a Firewall? List any FIVE important characteristics of a Firewall

1. Definition of Firewall

A Firewall is a network security device that monitors and controls incoming and outgoing network traffic.
Acts as a barrier between a trusted internal network and an untrusted external network (like the Internet).
Ensures that only authorized traffic is allowed while blocking unauthorized access.

2. Functions of a Firewall

1. Filters traffic based on predefined security rules.
2. Prevents unauthorized access to the network or system.
3. Protects against attacks like hacking, malware, and viruses.
4. Monitors network activity and logs suspicious events.
5. Enforces security policies within the network.

3. Five Important Characteristics of a Firewall

1. Traffic Filtering: Blocks or allows traffic based on source, destination, port, or protocol.
2. Access Control: Ensures only authorized users or systems can access the network.
3. Logging & Monitoring: Keeps records of network activity for security audits.
4. Policy Enforcement: Implements the organization's security rules and policies.
5. Protection Against Threats: Prevents unauthorized access, hacking attempts, malware, and DoS attacks.

Q4. Illustrate the working of a Packet Filtering Firewall with a Diagram

1. Definition of Packet Filtering Firewall

A Packet Filtering Firewall is a type of firewall that examines network packets individually.

Decides whether to allow or block packets based on rules such as:

Source IP address
Destination IP address
Source and destination port numbers
Protocol type (TCP, UDP, ICMP)

2. How It Works

1. Network data is sent in small units called packets.
2. Each packet is checked against firewall rules.
3. If the packet matches allowed criteria, it is forwarded to the network.
4. If it does not match the rules, it is dropped or blocked.
5. Operates mainly at the Network layer (Layer 3) and Transport layer (Layer 4) of OSI model.

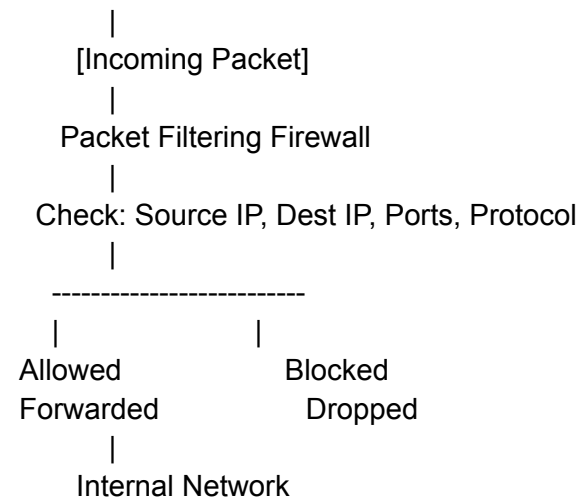
3. Advantages

Simple and fast because it checks only packet headers.
Provides basic network security by filtering unauthorized access.
Can be used in routers or standalone firewall devices.

4. Limitations

Cannot inspect packet contents (payload), so some attacks may pass.
Cannot prevent attacks using application layer vulnerabilities.

5. Packet Filtering Firewall Diagram



Q5. Describe any two types of Firewalls and their Working Principle

1. Packet Filtering Firewall

Definition

Examines individual network packets.

Allows or blocks packets based on predefined rules such as IP address, port number, and protocol.

Working Principle

1. Each packet is checked against the firewall rules.
2. If it matches the allowed criteria, it is forwarded to the network.
3. If it does not match, it is dropped.
4. Operates at Network Layer (Layer 3) and Transport Layer (Layer 4).

Pros

Fast and simple.

Provides basic network security.

Cons

Cannot check the contents of the packet.

Cannot protect against application layer attacks.

2. Stateful Inspection Firewall (or Dynamic Packet Filtering Firewall)

Definition

Keeps track of active connections and their states.

Monitors packets along with connection state to make better security decisions.

Working Principle

1. Maintains a state table of ongoing connections.
2. Checks source/destination IP, ports, protocol, and state of the connection.
3. Allows only packets that fit into the existing connection state.
4. Blocks packets that are unexpected or do not match the session.

Pros

More secure than packet filtering because it monitors connection states.
Can prevent certain types of attacks like spoofing.

Cons

Slightly slower than simple packet filtering.
Requires more memory and processing.

OR

Q6. What is a Firewall? Write Any Two Needs of Using a Firewall

1. Definition of Firewall

A firewall is a network security device or software that monitors and controls network traffic.
Acts as a barrier between a trusted internal network and an untrusted external network (like the Internet).
Ensures only authorized traffic passes, while blocking unauthorized or harmful traffic.

2. Needs of Using a Firewall

A. Protection from Unauthorized Access

Prevents hackers, attackers, and malicious users from accessing sensitive systems.
Controls which users or computers can connect to the network.
Example: Blocks access from unknown IP addresses.

B. Enforcement of Security Policies

Ensures the organization's security rules are followed.
Controls traffic based on ports, protocols, and applications.
Example: Only allows employees to access company web servers.

3. Additional Benefits (Optional)

1. Monitoring Network Traffic: Keeps logs for auditing and investigation.
2. Prevention of Malware & Attacks: Blocks viruses, worms, and DoS attacks.
3. Segmentation of Network: Separates sensitive internal networks from external traffic.

Q7. What is an Intrusion Detection System (IDS)? Briefly Explain the Two Main Approaches

1. Definition of IDS

Intrusion Detection System (IDS) is a security system that monitors network or computer system activities.
Its main purpose is to detect unauthorized access, attacks, or misuse.
IDS alerts administrators when suspicious activity occurs, helping prevent data theft, system damage, or service disruption.

2. Two Main Approaches of IDS

A. Misuse Detection (Signature-based Detection)

Compares current system activity with a database of known attack patterns (signatures).
Detects attacks that match known signatures.

Example: Detecting a virus using its known signature.

Pros: Accurate for known attacks.

Cons: Cannot detect new or unknown attacks.

B. Anomaly Detection (Behavior-based Detection)

Monitors normal behavior of users, systems, and network traffic.
Flags any activity that deviates from normal patterns as suspicious.

Example: Detecting a user logging in at unusual hours or from a new location.

Pros: Can detect new or unknown attacks.

Cons: May produce false positives (normal behavior flagged as attack).

Q8. Explain the Difference Between Misuse Detection and Anomaly Detection in IDS

1. Misuse Detection (Signature-Based Detection)

Definition: Detects intrusions by comparing activities against known attack patterns (signatures).

How it works: Maintains a database of attack signatures; any activity matching these signatures is flagged as an attack.

Pros:

High accuracy for known attacks

Low false positives for familiar attacks

Cons:

Cannot detect new or unknown attacks

Requires constant updating of signature database

2. Anomaly Detection (Behavior-Based Detection)

Definition: Detects intrusions by monitoring deviations from normal behavior of users or systems.

How it works: Creates a profile of normal activities; anything that deviates is considered suspicious.

Pros:

Can detect new or unknown attacks

Useful for detecting insider threats

Cons:

May generate false positives (normal activity flagged as attack)

Needs careful definition of "normal behavior"

3. Key Differences Table

Feature Misuse Detection Anomaly Detection

Detection Method Signature-based Behavior-based
Detects Known Attacks Yes Sometimes
Detects Unknown Attacks No Yes
False Positives Low Higher
Maintenance Frequent signature updates Update behavior profile

Q9. Design a Rule-Based IDS for Detecting Failed Login Attempts

1. Definition of Rule-Based IDS

Rule-Based IDS is a type of Intrusion Detection System that uses predefined rules to identify suspicious activities.
Rules are created based on expected behavior or known attack patterns.
Example: Detecting multiple failed login attempts from the same user or IP.

2. Objective

Detect brute-force attacks where attackers try to guess passwords by repeated login attempts.
Alert system administrators about potential intrusions.

3. Steps to Design the Rule-Based IDS

Step 1: Define Rules

Example Rule:
If a user or IP has more than 3 failed login attempts within 5 minutes, raise an alert.

Step 2: Monitor Login Activity

Track all login attempts with details:

Username
Source IP
Timestamp
Login success/failure

Step 3: Check Rules

Compare each login attempt with the predefined rule.
Count failed attempts per user/IP.

Step 4: Trigger Alerts

If the rule condition is met (e.g., 3+ failed attempts in 5 minutes):
Generate an alert or notification to the administrator.
Optionally block the user/IP temporarily.

Step 5: Logging and Reporting

Maintain a log of failed login attempts.
Helps in audit and forensic analysis.

4. Example Rule Table

Rule No	Condition	Action
1	3 failed logins in 5 min	Alert admin + block IP
2	Unusual login time	Alert admin
3	Login from new location	Alert admin

Q10. Demonstrate the Classification of Intruders: Masquerader, Misfeasor, and Clandestine Users

1. Introduction

Intruders are unauthorized users who try to access systems or networks without permission.
IDS and firewalls help in detecting and preventing intrusions.
Intruders are classified based on access rights and behavior into three main types.

2. Types of Intruders

A. Masquerader

Definition: An external attacker who pretends to be a legitimate user.

Access: Has no valid account on the system.

Activity: Tries to gain unauthorized access and steal information.

Example: A hacker logging in as an employee to access sensitive data.

B. Misfeasor

Definition: An insider who has authorized access but misuses it.

Access: Valid credentials for the system.

Activity: Performs unauthorized actions, violating security policies.

Example: An employee copying confidential files to personal storage.

C. Clandestine User

Definition: A user who gains unauthorized access secretly and hides presence.

Access: Unauthorized, usually unknown to system administrators.

Activity: Remains hidden, often for a long time, to collect information or disrupt systems.

Example: A spy installing a backdoor to monitor system activity.